第 23 章 物联网安全

0. 学习目标总览

教材给出本章六个学习目标：

1. 解释物联网的范围。
2. 列出并讨论物联网设备的5个主要组件。
3. 理解云计算和物联网的关系。
4. 定义漏洞修补。
5. 解释物联网安全框架。
6. 了解无线传感器网络的安全特性。

本章主线是从设备及其云连接出发，理解资源受限和物理暴露带来的安全问题，再用网关、分层防护与轻量级链路安全保护数据和控制操作：

```
物联网安全
  |-- 设备：感知、控制、通信与供电
  |-- 架构：边缘 -> 雾 -> 核心 -> 云
  |-- 漏洞修补：测试并部署固件、软件补丁
  |-- 安全框架：接入控制、数据保护与恢复
  |     |-- 防篡改与篡改检测
  |     `-- 网关认证、授权、维护与审计
  `-- MiniSec：无线传感器网络的链路安全
        |-- U：单播计数器
        |-- B：时间段与布隆过滤器
        `-- OCB：加密与认证
```

1. 学习目标 1：物联网的范围

物联网（IoT）是从大型家电到微型传感器等智能设备的扩展互连。把通信能力嵌入日常用品和工业设备后，可以实现人与物、物与物之间的通信，并通过采集数据、改变环境和控制设备来管理工厂、城市等更大的系统。

物联网主要由深度嵌入式设备驱动。许多设备只需低带宽、低频次地采集和交换数据；视频监控摄像机等设备则需要高带宽流媒体，不能把所有物联网设备都视为低流量设备。

教材按终端系统把因特网演化概括为四代：

阶段	典型设备及使用者	教材概括的连接特点
信息技术（IT）	企业 IT 人员采购的计算机、服务器、路由器和防火墙。	主要有线连接。
操作技术（OT）	OT 人员采购的医疗器械、SCADA、过程控制等带嵌入式 IT 的机器。	主要有线连接。
个人技术	消费者或员工购买的智能手机、平板和电子书阅读器。	无线连接，通常支持多种无线方式。
传感器或执行器技术	消费者、IT 或 OT 部门购买的单用途设备，构成大型系统的一部分。	通常采用单一无线连接。

第四代以海量嵌入式设备为特征，通常被视为物联网。其安全影响不仅是数据被窃取或篡改，还可能通过执行器直接改变物理环境。

2. 学习目标 2：物联网设备的五个主要组件

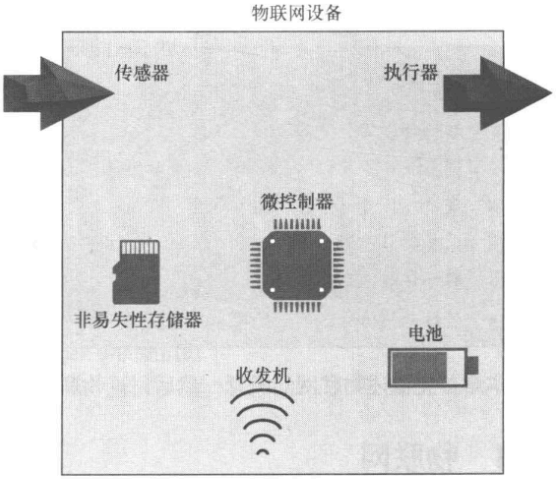


图 23.1　物联网的组件

图 23.1 物联网设备的组件

组件	功能	与其他组件的关系
传感器	测量物理、化学或生物参数，将观察结果转换为模拟电压或数字信号。	为微控制器等管理部件提供输入。
执行器	接收控制信号并改变环境中的某些参数。	把控制器的电子指令转换为对环境的作用。
微控制器	提供深度嵌入的处理与控制能力。	构成设备的“智能”，联系感知、控制和通信。
收发机	发送和接收数据。	通常通过 Wi-Fi、ZigBee 等无线方式连接设备或网关。
电源	为各组件供能，通常是一块电池。	电量限制影响设备运行和安全机制的设计。

图中还包括非易失性存储器，但学习目标要求掌握的五个主要组件是上述五项。

物联网设备还常包含 RFID 组件。RFID 系统由标签和阅读器组成：标签保存可识别物品的信息，阅读器在工作范围内读取，有时也能重写标签数据，再由计算机记录和格式化这些信息。RFID 支持物品识别，与测量环境参数的传感器功能不同。

3. 学习目标 3：云计算与物联网的关系

3.1 边缘、雾、核心与云

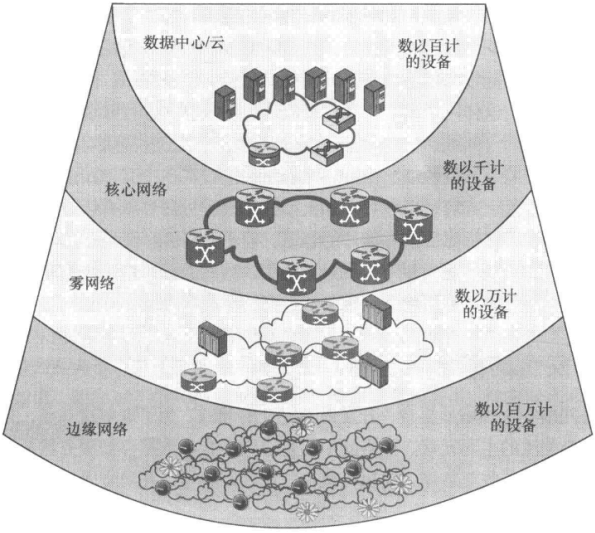


图 23.2　物联网和云环境

图 23.2 物联网与云环境的分层关系

层面	主要任务
边缘	传感器和执行器采集数据、相互通信并作用于环境；网关执行协议转换和基本数据聚合。
雾	在接近数据源的位置处理大量数据，把数据流转化为适合存储和进一步分析的信息。
核心	以高性能路由器、大容量链路和冗余连接互联分散的雾网络，并连接其他网络、数据库或私有云。
云	存储和处理聚合数据，托管设备管理、交互及数据分析应用。

雾计算的动机是减少把所有原始数据送到中心长期存储和处理的开销。传感器附近的处理既减轻网络容量压力，也能满足较低延迟要求，并应对安全和隐私方面的挑战。

3.2 雾计算的五类处理

1. **估计**：按标准判断数据是否需要送往更高层。
2. **格式化**：转换为适合统一处理的格式。
3. **扩展/解码**：处理加密数据及数据源等附加信息。
4. **净化/减少**：减少、汇总数据，降低流量和后续处理负担。
5. **评估**：判断是否达到阈值或触发警报，必要时改变数据目的地。

3.3 云与雾的区别

比较项	云计算	雾计算
资源位置	中心化的存储和处理设施。	靠近设备和传感器的边缘设施。
延迟	相对较高。	相对较低。
接入和移动性	固定或无线接入；教材比较中不以移动性为主要支持目标。	主要无线接入，支持移动性。
控制与服务访问	集中/分层控制，经核心访问服务。	分布式/分层控制，在边缘或手持设备访问服务。

比较项	云计算	雾计算
数据和规模	面向相对较少的分散用户，提供海量集中资源。	面向海量设备，数据可在各处产生和使用。
可用性特点	教材以较高可用性描述集中云设施。	节点可用性高度不稳定，依赖较高冗余。

云与雾各有侧重：雾在近端筛选和处理，核心负责互连，云再承担大规模存储、分析和应用管理。

4. 学习目标 4：漏洞修补

漏洞修补是通过更新固件或软件、部署安全补丁，修复已知安全缺陷，使设备不再容易被相应漏洞利用的过程。

4.1 物联网为什么难以修补

教材强调，嵌入式设备的供应链往往割裂：芯片制造商追求快速、低成本交付，设备制造商按价格和功能选用芯片，对附带固件和软件改动很少。最终用户可能既没有更新手段，也不知道何时、如何修补。

资源受限、低成本和快速部署进一步加重问题。未修补的传感器可能被用于向网络注入虚假数据；未修补的执行器还可能让攻击者操纵机器及其他设备的操作。

4.2 修补与持续维护

1. 在现场条件下测试安全补丁，随后尽可能快地部署。
2. 网关应支持固件和软件更新，以及自诊断、自修复和远程维护。
3. 同时禁用未用端口和服务，限制用户角色权限，持续审计和监控；在技术可行时使用杀毒软件和文件完整性检查。

修补是设备生命周期中的持续工作，需要与安全配置、运行监控和事故恢复共同实施。

5. 学习目标 5：物联网安全框架

5.1 生态系统的特殊困难

物联网的风险来自设备、网络、平台和供应链的相互作用。教材列出的挑战可归纳如下：

方面	主要问题
规模与复杂性	攻击面大，设备、通信协议、依赖关系和云元素众多，风险评估困难。
资源与成本	内存、处理能力、电源有限；低价竞争容易压缩安全功能。
部署与物理影响	快速进入商业及关键基础设施，安全规划可能不足；网络攻击可影响物理运行。
标准与集成	标准、法规和最佳实践碎片化，不同协议、认证方案和利益相关者要求难以统一。
人员与开发	专业知识不足，开发偏重功能和可用性，未把安全贯穿软件生命周期。
更新与责任	固件和软件难以修补，复杂供应链使事故责任不清。

5.2 七项安全目标

安全目标	主要措施
限制逻辑接入	使用单向网关、防火墙和多层网络；企业与物联网使用独立认证机制及凭据，关键通信置于最安全的层。
限制物理访问	采用锁、读卡器、看守等物理访问控制。
防止组件被编程入侵	测试并及时部署补丁，禁用闲置端口和服务，限制角色权限，跟踪审计。
防止未授权修改数据	保护传输中，尤其跨网络边界的数据，以及静止数据。

安全目标	主要措施
检测事件和事故	尽早发现攻击、组件失效、服务不可用及资源耗尽，打断攻击链。
不利条件下保持功能	为关键组件提供冗余，避免故障扩散；必要时从全自动运行降级到人工参与或完全手动运行。
事故后恢复	预先建立事故响应计划，在事故发生后快速恢复系统。

5.3 防篡改与篡改检测

篡改是未经授权地修改设备或系统，改变预期功能并降低安全性。防篡改提供被动保护；篡改检测使系统察觉非法物理访问。两者对部署在安全场所以外的边缘和雾节点尤其重要。

手段	作用与例子
提高物理侵入难度	坚硬外壳、锁、安全螺栓、紧密封装等。
留下可见证据	特殊封条和胶带在被打开或破坏后显示篡改痕迹。
开关检测	用磁性开关、压力触点等发现开盖、边界破坏或移动。
传感器检测	用温度、辐射、电压和功率传感器发现异常环境或电气干扰。
电路检测	用柔性电路、电阻丝或光纤封装检测损坏。

5.4 网关的保护边界和职责

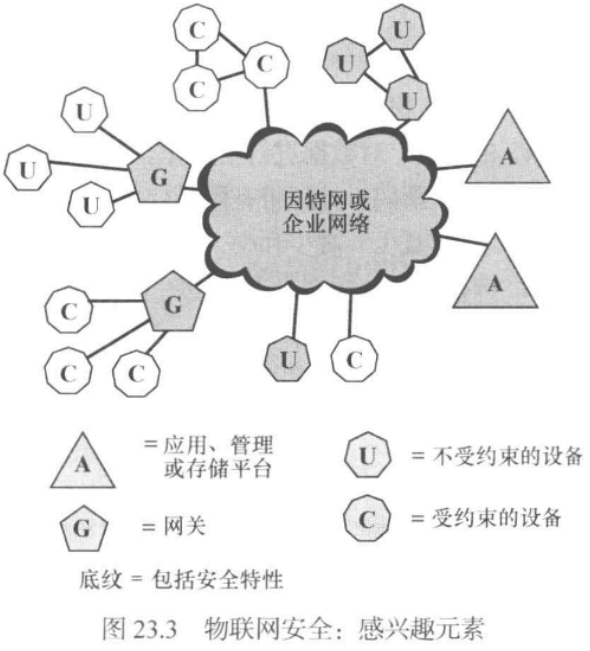


图 23.3　物联网安全：感兴趣元素

图 23.3 不同设备和网关的安全能力及互连场景

受约束设备通常只有有限安全能力，甚至没有安全功能；不受约束设备可能自行实现安全通信。网关可通过 TLS、IPsec 等保护它与中央应用、管理或存储平台之间的通信。

网关到中央平台的安全连接，不会自动保护设备到网关这一段，也不会自动保护设备内的存储数据。 受限设备缺少加密能力时，一些保护要求难以在设备端实现，必须明确实际保护范围。

ITU-T Y.2066 从六方面提出总体要求：通信安全、数据管理安全、服务提供安全、不同安全策略与技术的集成、相互认证和授权、安全审计。要求覆盖数据的采集、存储、传输、聚合、处理及应用访问，并保护隐私。

Y.2067 进一步规定网关能力：

1. 标识对连接设备的每次访问。
2. 按设备能力和应用要求支持单向或相互设备认证，并与应用相互认证。
3. 保护设备和网关内的静止数据，以及设备到网关、网关到应用的传输数据。
4. 保护设备和网关的隐私。
5. 支持自诊断、自修复及远程维护。
6. 支持固件和软件更新。
7. 支持本地/远程、自动/手动及基于策略的动态配置。

单向认证只验证一方身份，相互认证则双方均验证对方。医疗、位置、移动轨迹和应用使用等数据可能由设备持续收集，隐私保护必须贯穿这些处理环节。

5.5 四个层面上的安全部署

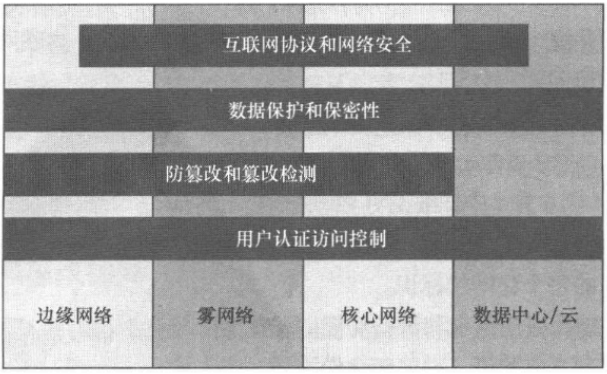


图 23.5　物联网安全环境

图 23.5 边缘、雾、核心及云中的安全功能范围

用户认证与访问控制、数据保护与保密性、协议及网络安全贯穿物联网各层；防篡改和篡改检测重点部署在设备、雾网络，也延伸到核心网络中物理暴露的组件。

访问控制可采用 RBAC：先把权限分配给角色，再按职责把用户分配给相应角色，以管理设备及其生成数据的访问。逻辑控制、物理防护和通信保护共同构成分层安全体系。

6. 学习目标 6：无线传感器网络的安全特性

6.1 TinyOS 与 MiniSec

TinyOS 面向内存、处理时间、实时响应和功耗受限的小型嵌入式系统，主要应用是无线传感器网络。教材给出的典型配置需要约 48 KB 代码和 10 KB RAM。

MiniSec 是 TinyOS 的开源链路级安全模块，以较少内存和较低能耗提供保密性、认证和重放保护。其设计要求包括：

要求	含义
数据认证	验证消息来自共享密钥的合法节点，并在传输中保持不变。
保密性	防止未授权方获知消息内容。
重放保护	阻止攻击者记录数据包后再次发送并被接受。
新鲜度	MiniSec 提供弱新鲜度：接收方不依赖本地参考时间点，也能对消息作局部排序。
低能量开销	尽量减少通信开销，并只使用对称密码。
容忍消息丢失	能在无线网络较高丢包率下保持工作。

MiniSec 采用 Skipjack 分组密码和 OCB 操作模式。Skipjack 的 80 位密钥、较低计算量和较小内存占用体现了早期受限设备的权衡；教材同时指出，80 位密钥通常不安全，今后的模块应采用较新的轻量级密码。不能把这一实例理解为对所有物联网场景的通用算法建议。

6.2 MiniSec-U：单播保护

两种 MiniSec 模式都使用带时变值的 OCB。数据包包含加密数据、OCB 认证标签和计数器信息；为帮助同步，计数器的最低有效位以明文发送。

MiniSec-U 为每个发送方在接收端维护本地计数器：

1. 发送方使用严格递增的计数器，使重复消息使用不同的时变值加密。
2. 接收方观察到某计数器值后，拒绝相同或更小值的数据包，从而防止已接收消息被重放。
3. 大量丢包造成失步时，通过重同步协议恢复一致。

其代价是接收端必须保存每个发送方的状态。广播中发送方和接收方众多，逐一保存状态、执行重同步会带来过高的内存与通信开销。

6.3 MiniSec-B：广播保护

MiniSec-B 结合时间段与布隆过滤器，避免为每个发送方保存单独的重放保护状态。

- 将时间划分为长度为 t 的时间段 $E_1, E_2, \ldots$，以当前或前一个时间段参与时变值构造，排除更早时间段的重放。
- 再利用布隆过滤器检查时间段内的重复消息；未被判为重放的消息加入过滤器，重放消息被丢弃。
- 时变值元素由发送方标识、时间段和共享计数器组合，即 $\mathrm{nodeID}.E_i.C_{ab}$。这里的点表示字符串组合，不是乘法。

比较项	MiniSec-U	MiniSec-B
通信场景	单播。	多源广播。
重放防护	每个发送方的同步计数器。	时间段与布隆过滤器。
扩展性代价	多发送方会增加接收端计数器状态。	无须逐发送方保存重放状态，适合大型网络。
丢包相关处理	大量丢包后需要重同步。	通过时间段机制配合过滤器工作。

6.4 OCB 的作用与基本结构

偏移码本模式（OCB）通过一次消息处理生成密文和认证标签，允许分组并行运算，适合能量受限的节点。教材所示结构对每个消息分组调用一次分组密码，另需两次调用完成该消息的处理。

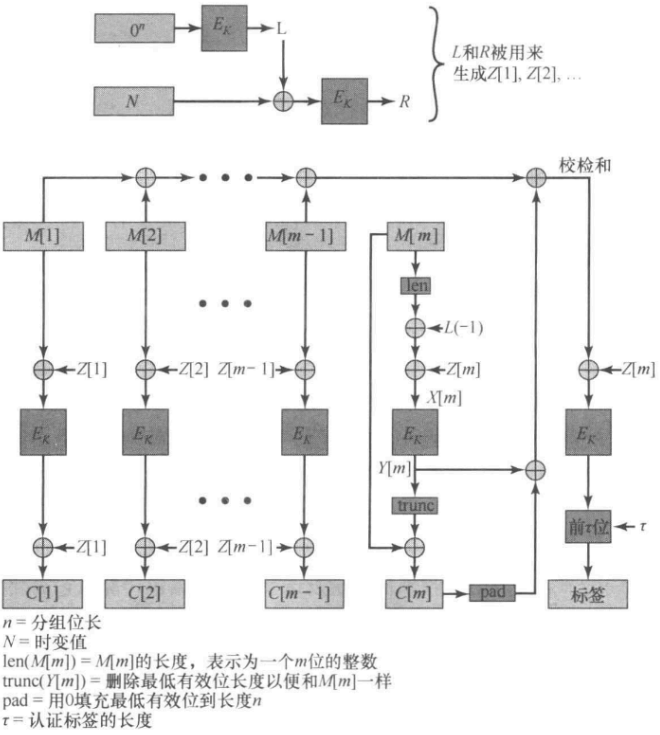


图 23.6　OCB 加密和认证

图 23.6 教材所示 OCB 加密与认证结构

设消息为 M，底层分组长度为 n 位，加密密钥为 K，消息分组数为

$$m = \left\lceil \frac{\mathrm{len}(M)}{n} \right\rceil .$$

其中 len 按比特计数。教材以 AES、$n = 128$ 为常见示例；MiniSec 则把 OCB 与其选定的分组密码配合使用。最后一块可以不足 n 位，并采用单独处理。

对前 $m-1$ 个完整分组：

$$\begin{aligned} C[i] &= E_K\big(M[i] \oplus Z[i]\big) \oplus Z[i], \\ M[i] &= D_K\big(C[i] \oplus Z[i]\big) \oplus Z[i], \qquad 1 \le i < m. \end{aligned}$$

E_K、D_K 分别表示分组加密和解密，$\oplus$ 表示异或。与 ECB 直接加密相同明文块不同，OCB 在加密前后加入随位置和消息变化的偏移量 $Z[i]$，避免固定的相同明文块到相同密文块的映射。

6.5 时变值和偏移量

时变值 N 不需要保密，但**同一密钥下每条消息必须使用不同的 N**。教材给出的偏移生成过程为：

$$\begin{aligned} L(0) = L &= E_K(0^n), \\ R &= E_K(N \oplus L), \\ L(i) &= 2 \cdot L(i-1), \qquad 1 \le i \le m, \\ Z[1] &= L \oplus R, \\ Z[i] &= Z[i-1] \oplus L\big(\mathrm{ntz}(i)\big), \qquad 2 \le i \le m. \end{aligned}$$

乘法在有限域 $\mathrm{GF}(2^n)$ 中进行；$\mathrm{ntz}(i)$ 是 i 的二进制表示中末尾连续零的个数。偏移由密钥、时变值及分组位置共同决定，重复使用时变值会破坏这一使用前提。

6.6 最后一块、校验和与认证标签

令最后一块的位长为 $\ell = \mathrm{len}(M[m])$，以 $[\ell]_n$ 表示其 n 位整数编码，并定义 $L(-1) = L \cdot 2^{-1}$，其中逆元和乘法均在上述有限域中计算。则：

$$
\begin{aligned}
X[m] &= [\ell]_n \oplus L(-1) \oplus Z[m], \\
Y[m] &= E_K(X[m]), \\
C[m] &= M[m] \oplus \mathrm{MSB}_\ell\big(Y[m]\big).
\end{aligned}
$$

$\mathrm{MSB}_r(X)$ 表示取 X 的最高 r 位。末块通过截断得到等长掩码，因此密文数据部分与明文等长，认证标签是额外输出。

把末块密文的低位补零至 n 位，记为 $C[m] \,\|\, 0^{n-\ell}$，得到：

$$
\begin{aligned}
\mathrm{Checksum} &= \left(\bigoplus_{i=1}^{m-1} M[i]\right) \oplus Y[m] \oplus \big(C[m] \,\|\, 0^{n-\ell}\big), \\
\mathrm{Tag} &= \mathrm{MSB}_\tau\left(E_K\big(\mathrm{Checksum} \oplus Z[m]\big)\right).
\end{aligned}
$$

其中 $\|$ 表示比特串连接，τ 是标签位长。接收方解密并重算校验和与标签，与收到的标签比较，验证通过后接受明文。标签用于认证，而 MiniSec 还需计数器或时间段等机制判断新鲜度和拒绝重放。

本章关键术语整理

术语	核心含义
IoT	智能物品与嵌入式设备互连，实现感知、通信和环境控制。
传感器 / 执行器	前者把环境参数变成信号，后者把控制信号转为环境作用。
微控制器	为物联网设备提供嵌入式处理与控制能力的组件。
RFID	通过标签和阅读器，以无线方式识别物品并获取标签信息的技术。
雾计算	在接近边缘数据源的位置提供处理和存储，降低传输与中心处理负担。
漏洞修补	通过固件、软件更新和安全补丁修复已知缺陷。
防篡改 / 篡改检测	分别提供被动物理保护，以及发现非法物理访问的能力。
物联网网关	连接设备与上层网络，提供协议转换、聚合和相应安全服务。
RBAC	把权限分配给角色，再根据职责为用户分配角色的访问控制方式。
TinyOS	面向资源受限嵌入式设备，主要用于无线传感器网络的操作系统。
MiniSec	TinyOS 的低能耗、低内存链路级安全模块。
弱新鲜度	不依赖本地参考时间点，对接收消息进行局部排序的能力。
MiniSec-U / MiniSec-B	分别以逐发送方计数器、时间段与布隆过滤器保护单播和广播。
Skipjack	教材中 MiniSec 使用的 80 位密钥分组密码。
OCB	使用偏移量，同时生成密文和认证标签的分组密码操作模式。
时变值 N	同一密钥下不得重复的消息级输入，可以公开传递。
偏移量 $Z[i]$	由密钥、时变值和位置确定，用于加密前后异或的值。
认证标签	接收方重新计算并比较，用来验证消息的认证信息。

学习目标自检

1. 能否解释物联网中“物”的范围、四代终端演化，以及低带宽设备与视频设备的差别？
2. 能否说明传感器、执行器、微控制器、收发机和电源的作用，并区分 RFID 识别与传感器测量？

3. 能否描述边缘、雾、核心和云各自的职责，列出雾计算的五类处理并比较云与雾？
4. 能否定义漏洞修补，解释物联网供应链和设备限制导致的修补困难，并说明测试、部署与维护要求？
5. 能否概括物联网生态系统的安全挑战、七项安全目标、防篡改与检测方法、网关职责和实际保护边界？
6. 能否说明 MiniSec 的六项要求、U/B 两种模式的防重放机制，以及 OCB 的时变值、偏移、末块处理和标签验证？